

VinhoSend - Relatório de requisitos de segurança

Projeto: marketplace de vinhos para cadastro, anúncio, compra/reserva e acompanhamento de vendas. Este relatório aponta requisitos implementados no código, com localização simples para apresentação em defesa.

Resumo técnico: o sistema possui autenticação, múltiplos usuários, CRUD de vinhos, marketplace, persistência MySQL, Repository Pattern, criptografia AES-256-GCM, upload seguro de imagem, testes automatizados e GitHub Actions.

Tipo	Requisito implementado	Onde mostrar no código
DFD/STRIDE 1 - Spoofing	Login obrigatório e sessão validada contra o banco.	config/sessao.php; páginas internas; controladores protegidos
DFD/STRIDE 2 - Tampering	CSRF em formulários que alteram dados.	config/seguranca.php; painel.php; marketplace.php; meus_anuncios.php
DFD/STRIDE 3 - Information Disclosure	Usuário só acessa dados próprios e dados sensíveis são cifrados.	VinhoRepositorio.php; AnuncioRepositorio.php; CompraRepositorio.php; CriptografiaServico.php
Codificação segura 1 - OWASP ASVS	Senha armazenada com hash seguro e verificada no login.	cadastar_usuario.php; entrar.php
Codificação segura 2 - OWASP/CWE-89	Prepared statements para evitar SQL Injection.	todos os arquivos em repositorios/
Codificação segura 3 - OWASP/CWE-79	Escape de saída para reduzir XSS.	config/seguranca.php; telas PHP
Livre 1	Bloqueio temporário após tentativas inválidas de login.	entrar.php; UsuarioRepositorio.php; config/config.php
Livre 2	Auditoria das ações importantes.	AuditoriaRepositorio.php; controladores/
Livre 3	Upload seguro de foto dos vinhos.	UploadImagemServico.php; painel.php; uploads/.htaccess
Livre 4	Marketplace com regras de autorização e estoque.	AnuncioRepositorio.php; CompraRepositorio.php; marketplace.php

Criptografia

A criptografia aparece em `servicos/CriptografiaServico.php`. O projeto usa AES-256-GCM com `openssl_encrypt/openssl_decrypt`. A descrição do vinho, as observações do anúncio e o endereço de entrega são cifrados antes de serem salvos no banco e decifrados apenas quando exibidos para o usuário autorizado.

Login obrigatório

As páginas internas chamam `exigir_login()`. A função está em `config/sessao.php` e agora confere se o usuário da sessão ainda existe na tabela `usuarios`. Isso evita sessão antiga acessando o sistema e corrige o caso em que o `logout` tentava auditar um usuário apagado.

Upload de fotos

A foto do vinho é opcional e fica em `uploads/vinhos`. O upload aceita apenas JPG, PNG e WEBP até 2 MB, gera nome aleatório e bloqueia execução de PHP na pasta de upload usando `.htaccess`.

Testes e Actions

Os testes ficam em `tests/` e rodam com `php tests/run.php`. O workflow `.github/workflows/tests.yml` executa lint PHP e os testes automaticamente no GitHub Actions.

Comando de teste esperado: `php tests/run.php`. Resultado esperado: Testes executados com sucesso: 7.